Android 隐私检测系统
Lab4 系统设计与实验汇报

证据驱动的知情权、同意权、访问权自动化审计

李禹江，张博涵，蒋兴宇

我的刀盾队

2026-05-25

目录

1. 背景与目标
2. 系统总体设计
3. 实验设计
4. 实验结果
5. 总结与展望

研究背景

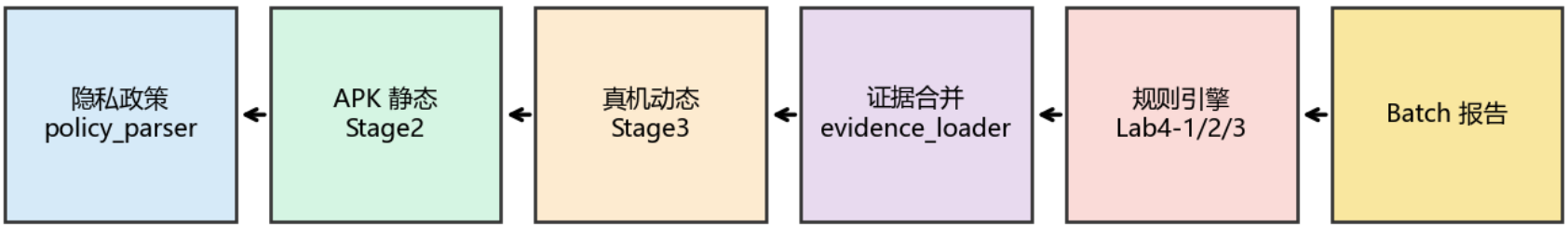
- 课程/课题 **Lab4** 要求从「文本承诺」延伸到「技术可验证」：政策声明是否与真实采集、开关控制、副本导出一致。
- 早期方案（plan.md、开发计划.md）以 **LLM 主导**判断为主；现实现以 **证据包 + 规则引擎 + 法律知识库**为主，LLM 仅保留在 Part1 政策句级审计历史链路。
- 本汇报对齐 **系统设计 Lab4**：总体架构、模块划分、数据流、三项权利实验与局限说明。
- 详细实验数据见 src/output/result/result_20260525.md。

Lab4 三项权利与评价维度

维度	核心问题	本批结果
Lab4-1 知情权	政策声明 PII 类型 vs 多源观测是否一致	**9/9** 成功
Lab4-2 同意权	关闭隐私开关前后 Frida 命中是否停止	**0/9** 有效实证
Lab4-3 访问权	声明、运行时与「副本」字段是否覆盖	流水线 **9/9**；覆盖率均为 0

Job ID 前缀：`exp_stage3_20260525`；样本 9 App（`apps_lab4_batch.txt`）。

系统总体架构



- **输入**：`input/pii_text/<App>.txt`、APK（可选）、`oldsrc` 历史 JSON。
- **Stage2**：Exodus + Androguard → `static_evidence.json`。
- **Stage3**：Appium 政策路径 + Frida → `dynamic_evidence.json`。
- **合并**：`evidence_loader` + `privacy_knowledgebase` → `lab4_1_evidence/<App>.json`。
- **输出**：`lab4_1/2/3` 报告 + batch summary + manifest。

端到端 Pipeline（程序管线）

1. **政策解析**：policy_parser → declared_pii[]
2. **静态分析**：stage2_static（Exodus + Androguard）
3. **动态取证**：stage3_dynamic（appium_runner + Frida hooks）
4. **证据导入**：import-oldsrc、build-evidence-bundles
5. **知识库**：kb-build → feasible_evidence[]
6. **权利审计**：lab4-1-audit / lab4-2-audit / lab4-3-audit
7. **批量**：batch + --retry + 日志归档

统一入口：python -m privacy_audit.cli（工作目录 project/src）。

核心模块划分

ingestion

- `policy_parser`
- `evidence_loader`
- `privacy_knowledgebase`

analyzers

- `compare_engine`（Lab4-1）
- `consent_compare`（Lab4-2）
- `access_compare`（Lab4-3）

dynamic

- `appium_runner`
- `element_tap`（Tab/齿轮/头像）
- `frida_collector`

reporting

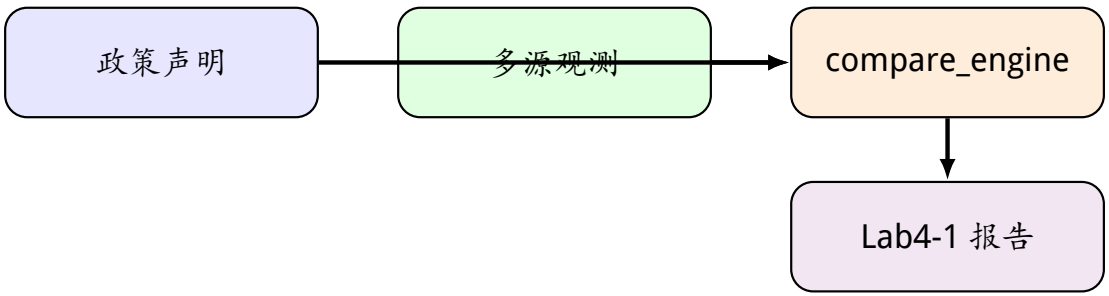
- `lab4_1_report` 等
- `batch` / manifest

设计原则：与早期计划的差异

方面	早期（plan / 开发计划）	现实现
判定主体	LLM 直接输出 verdict	规则引擎 + 可溯源 prove-nance
动态测试	泛化 UI 探索	政策路径驱动 + 分 App 适配
证据来源	单一通道	static + dynamic + oldsrc + KB
工程形态	脚本分散	统一 CLI + batch + job id

Lab4-1 判定逻辑（知情权）

- 输入：`declared_pii[]`（政策）与 `observed_pii[]`（合并证据）。
- 输出 verdict：`consistent`、`inconsistent_high_risk`、`declared_not_observed`、KB 相关类型等。
- 每条结论附带 `sources[]` / `provenance`，便于答辩追问「证据从哪来」。



实验环境与样本

- **环境**：Windows + MuMu（ADB）+ Appium 4723 + Frida（版本需与 frida-server 匹配）。
- **样本**：Keep、小红书、支付宝、LOFTER、智联招聘、世纪佳缘、好大夫医生版、东方财富、小荷健康。
- **包名映射**：input/app_packages.json（小荷：com.lvsongguo）。
- **批次**：exp_stage3_20260525_lab4_1/2/3。

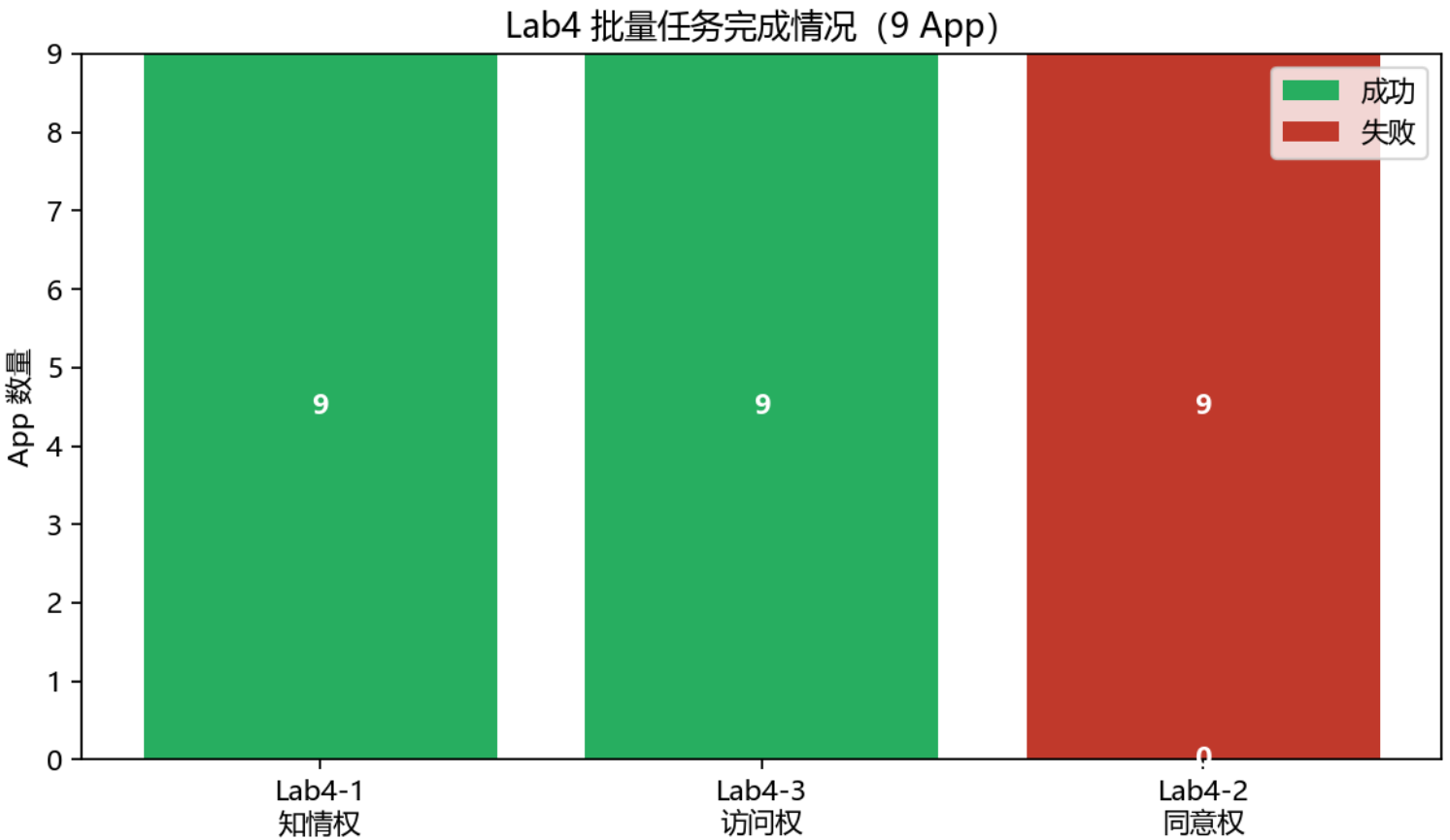
Stage3 动态取证

- 命令：stage3-dynamic --app < 名 > --package < 包 > --policy-txt ...
- 产物：output/stage3_dynamic_real/<App>/dynamic_evidence.json、截图、stage3_run.log。
- **共性**：9 App 均有产物；frida_runtime_events = 0（仅 hook_loaded 登记）。
- Lab4-1 的 observed_pii 主要来自 static、oldsrc、legacy、KB，**不能**全部表述为本次 Frida 实测。

分 App UI 自动化要点

App	要点
世纪佳缘	底部 Tab 文案为 " 我"（含空格）；按 bounds 点最右 Tab，避免误点「推荐」
小荷健康	设置无文字；UserPage **右上角最右侧**齿轮为设置（左侧为扫一扫）
支付宝	需精确匹配「我的」等文案，避免宽泛「我」
其他	政策路径 token + `element_tap` 关键词/头像/齿轮兜底

批量任务完成情况



Lab4-1、Lab4-3

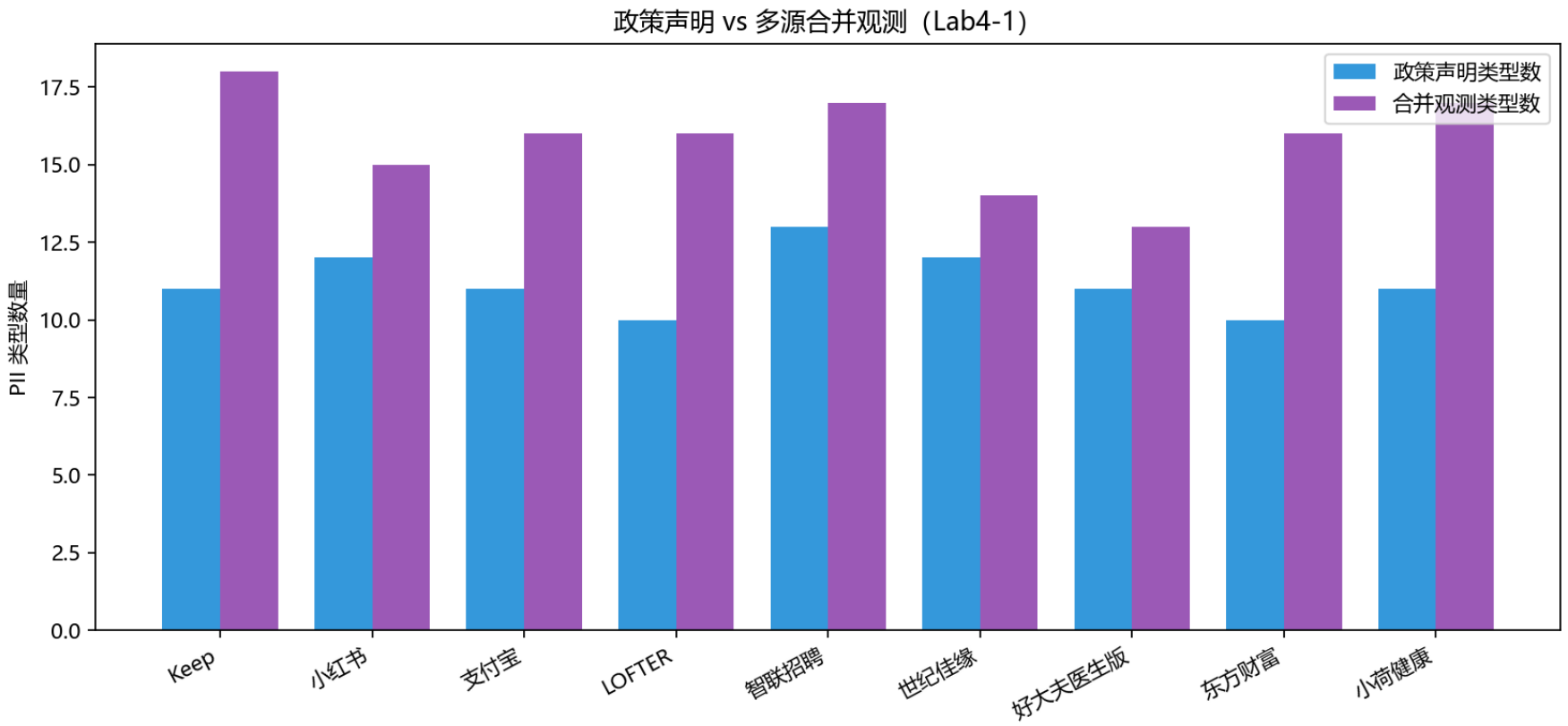
程序批量 **9/9 成功**；Lab4-2 因无有效运行时前后对比，报告均为 `report_status_failed`。

Lab4-1 全样本合计（9 App）

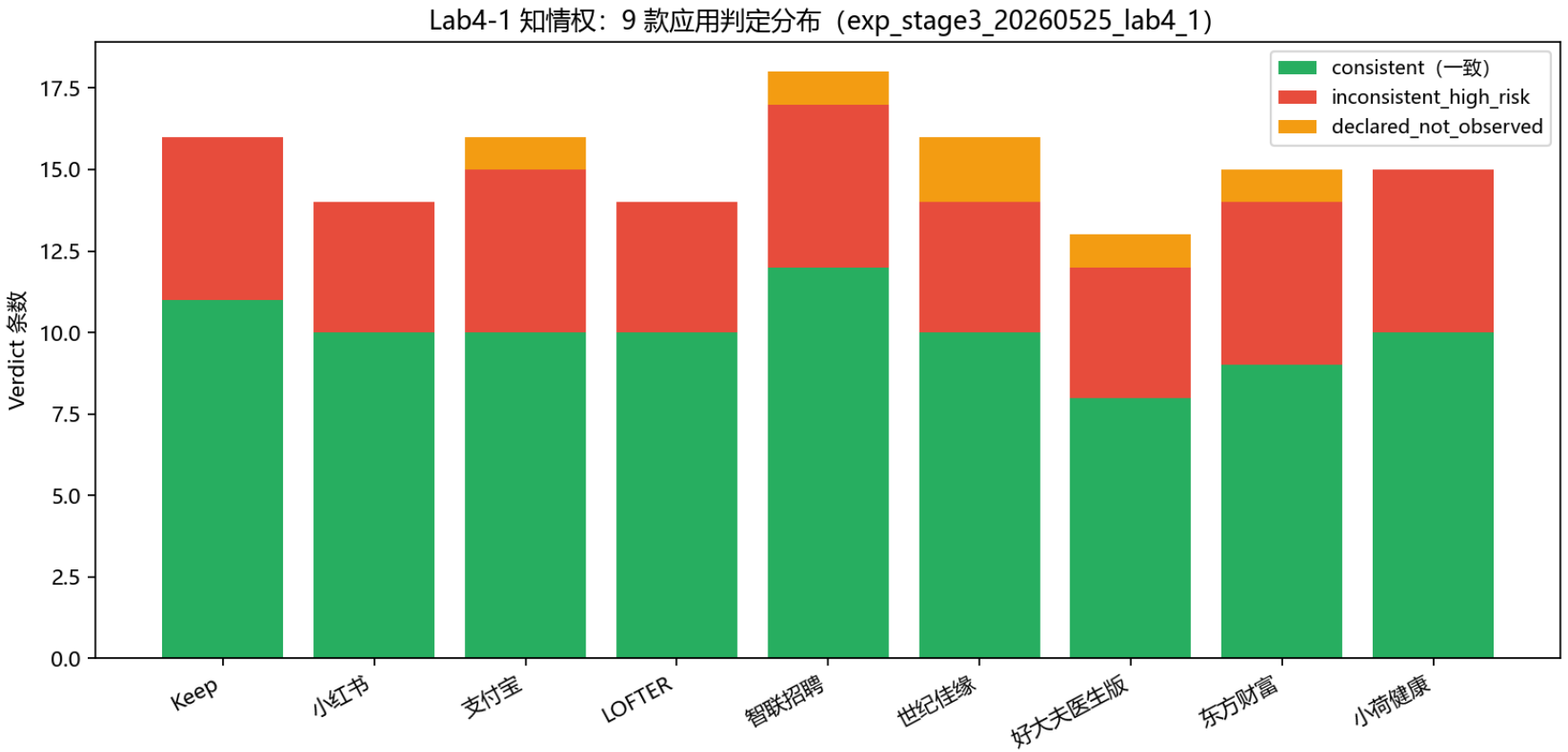
Verdict	条数
consistent	90
inconsistent_high_risk	41
declared_not_observed	6

- **consistent**：政策声明且多源证据可支撑。
- **inconsistent_high_risk**：证据观测到但政策未充分声明（答辩可重点展开）。
- **declared_not_observed**：政策声明但当前证据链未观测到。

Lab4-1：政策声明 vs 合并观测



Lab4-1：分应用 Verdict 分布



Lab4-1 分 App 数据摘要

App	声明	观测	一致	高风险	未观测	
Keep	11	18	9	9	2	
小红书	12	18	10	8	2	
支付宝	12	18	10	8	2	
LOFTER	12	18	10	8	0	
智联招聘	12	18	10	8	0	
世纪佳缘	12	18	10	8	0	
好大夫医生版	12	18	10	8	0	
东方财富	12	18	10	8	0	
小荷健康	12	18	10	8	0	

数据来源：batch_lab4-1_exp_stage3_20260525_lab4_1_summary.json。

典型案例：高风险不一致

- 现象：observed_count 常大于 declared_count（静态 SDK、历史审计、KB 推断并入观测集）。
- 解读：应用在政策中未充分声明的类型，在技术侧或知识库侧已有信号 → inconsistent_high_risk。
- 答辩话术：强调 **证据链分项**（static / oldsrc / kb / dynamic），避免笼统「Frida 抓到了」。
- 可展示单 App <App>_lab4_1_report.json 中一条 inconsistent_high_risk 的 sources。

Lab4-2 同意权（未完成有效实证）

- 设计：对比「个性化推荐/隐私开关」关闭前、后 Frida 有效 API 命中。
- 实际：before 为本次真机包，after 多为 oldsrc derived；且无 frida_runtime_events。
- 结果：9/9 report_status_failed，review_needed。
- 后续：关开关后 **二采** + 稳定 attach + 明确「有效事件」定义。

Lab4-3 访问权（流水线成功 ≠ 合规结论）

- 设计：declared vs runtime_observed_pii vs lab4_3_copy 字段覆盖。
- 实际：lab4_3_copy 来自 oldsrc access_result.json（可用性测试字段）；非用户导出副本。
- 各 App coverage_rate = 0，runtime_observed_pii = []。
- CLI 注意：lab4-3-audit --dynamic-dir（非 --dynamic-evidence-dir）。

阶段性结论

- 已完成 **工程化端到端流水线**：政策 → 静/动证据 → 合并 → Lab4 batch 报告。
- **主实验结论**来自 Lab4-1：9 App 可解释知情权审计，合计 90 条一致、41 条高风险不一致。
- Stage3 **UI 自动化**已覆盖 9 App 政策路径，并针对世纪佳缘、小荷等完成适配。
- 须在汇报中诚实说明：Frida 运行时事件为 0、Lab4-2 未过、Lab4-3 副本语义为历史可用性数据。

后续工作

1. 修复 Frida attach / hook，使 `frida_runtime_events` > 0，支撑 Lab4-2。
2. Lab4-2：关「个性化推荐」后二次 Stage3，形成真实 before/after 对比。
3. Lab4-3：采集真实个人信息导出 JSON，替换 oldsrc 可用性字段。
4. 可选：从 Lab4-1 挑 1–2 个 App 做口述案例 + 截图/报告片段展示。

复现与文档索引

- 实验报告：src/output/result/result_20260525.md
- 图表生成：ppt/generate_lab4_ppt.py
- 本 TeX：ppt/lab4_slide.tex；PPTX：ppt/系统设计 Lab4.pptx
- 编译：xelatex lab4_slide.tex（需先生成 figures_lab4/）

感谢聆听！

Q & A